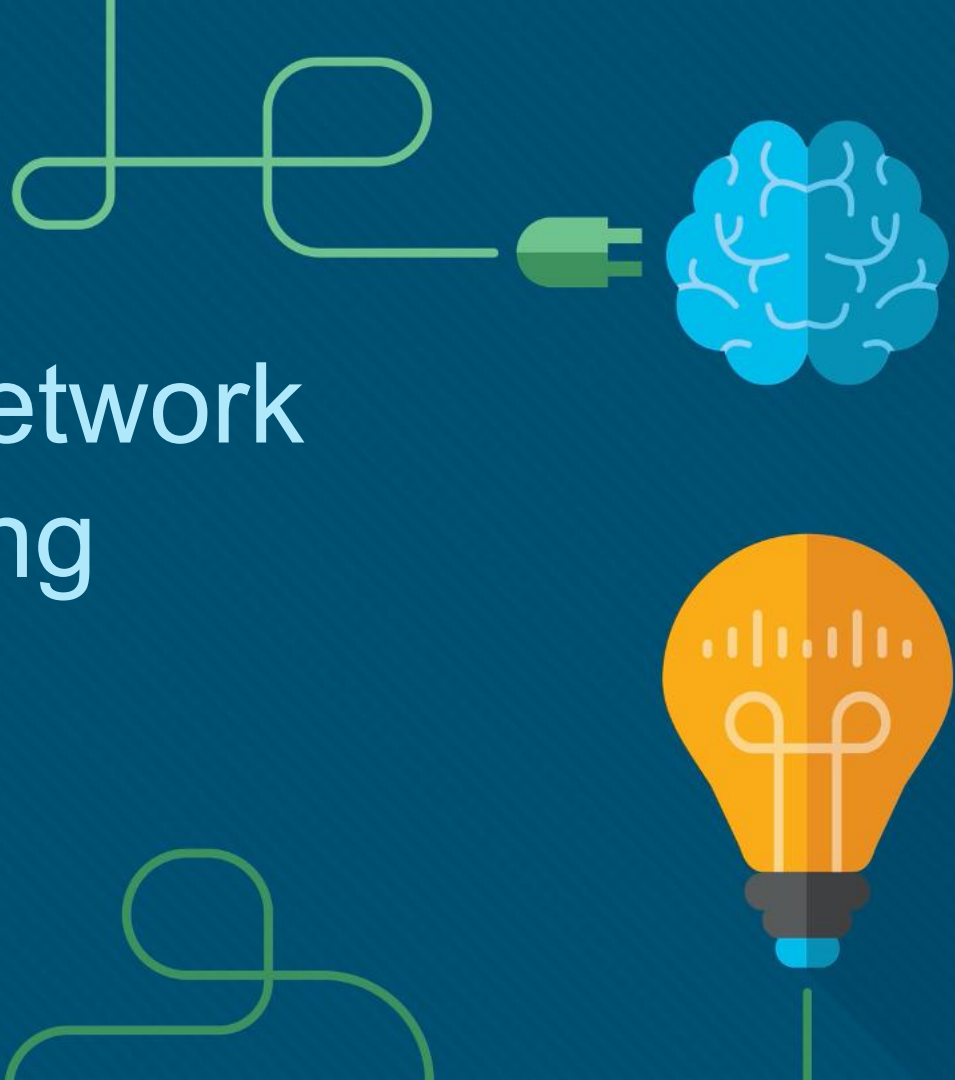




Module 22: Network Security Testing

Networking Security v1.0
(NETSEC)



Module Objectives

Module Title: Network Security Testing

Module Objective: Describe the various techniques and tools for network security.

Topic Title	Topic Objective
Network Security Testing	Describe the techniques used in network security testing.
Network Security Testing Tools	Describe the tools used in network security testing.

22.1 Network Security Testing Techniques

Operations Security

Operations security starts with the planning and implementation process of a network. During these phases, the operations team analyzes designs, identifies risks and vulnerabilities, and makes the necessary adaptations. The actual operational tasks begin after the network is set up and include the continual maintenance of the environment.

Some security testing techniques are predominantly manual, and others are highly automated. Regardless of the type of testing, the staff that sets up and conducts the security testing should have significant security and networking knowledge in these areas:

- Device hardening
- Firewalls
- IPSs
- Operating systems
- Basic programming
- Networking protocols, such as TCP/IP
- Network vulnerabilities and risk mitigation

Testing and Evaluating Network Security

During the implementation stage, security testing is conducted on specific parts of the network. After a network is fully integrated and operational, a Security Test and Evaluation (ST&E) is performed. An ST&E is an examination of the protective measures that are placed on an operational network.

Objectives of ST&E include the following:

- Uncover design, implementation, and operational flaws that could lead to the violation of the security policy.
- Determine the adequacy of security mechanisms, assurances, and device properties to enforce the security policy.
- Assess the degree of consistency between the system documentation and its implementation.

Tests should be repeated periodically and whenever a change is made to the system.

Types of Network Tests

After a network is operational, ascertain its security status. Many security tests can be conducted to assess the operational status of the network:

- **Penetration testing** - Simulate attacks to determine the feasibility of an attack and possible consequences if one were to occur.
- **Network scanning** - Includes software that can ping computers, scan for listening TCP ports and display which types of resources are available on the network.
- **Vulnerability scanning** - Detects potential weaknesses in the tested systems.
- **Password cracking** - Tests and detects weak passwords that should be changed.
- **Log review** - Filter and review security logs to detect abnormal activity.
- **Integrity checkers** - Detects and reports changes in the system.
- **Virus detection** - Detects and removes computer viruses and other malware.

Applying Network Test Results

Network security testing results can be used in several ways:

- To define mitigation activities to address identified vulnerabilities
- As a benchmark to trace the progress of an organization in meeting security requirements
- To assess the implementation status of system security requirements
- To conduct cost and benefit analysis for improvements to network security
- To enhance other activities, such as risk assessments, certification and authorization (C&A), and performance improvement efforts
- As a reference point for corrective action

22.2 Network Security Testing Tools

Network Testing Tools

There are many tools available to test the security of systems and networks. Some of these tools are open source while others are commercial tools that require licensing. Various software tools can be used to perform network testing including:

- **Nmap/Zenmap** - This discovers computers and services on a computer network, thus creating a map of the network.
- **SuperScan** - Designed to detect open TCP and UDP ports, determine what services are running on those ports, and to run queries, such as whois, ping, traceroute, and hostname lookups.
- **SIEM (Security Information Event Management)** - Used in enterprise organizations to provide real time reporting and long-term analysis of security events.
- **GFI LANguard** - This is a network and security scanner which detects vulnerabilities.
- **Tripwire** - Assesses and validates IT configurations.
- **Nessus** - Vulnerability scanning software, focusing on remote access, misconfigurations, and DoS against the TCP/IP stack.
- **L0phtCrack** - Password auditing and recovery application.
- **Metasploit** - Provides information about vulnerabilities and aids in penetration testing and IDS signature development.

Nmap and Zenmap

Nmap is a commonly used, low-level scanner that is available to the public. It has an array of excellent features which can be used for network mapping and reconnaissance.

The basic functionality of Nmap allows the user to accomplish several tasks, as follows:

- **Classic TCP and UDP port scanning** - This searches for different services on one host.
- **Classic TCP and UDP port sweeping** - This searches for the same service on multiple hosts.
- **Stealth TCP and UDP port scans and sweeps** - This is similar to classic scans and sweeps, but harder to detect by the target host or IPS.
- **Remote operating system identification** - This is also known as OS fingerprinting.

Advanced features of Nmap include protocol scanning, known as Layer 3 port scanning.

SuperScan

SuperScan is a Microsoft Windows port scanning tool. It runs on most versions of Windows and requires administrator privileges. SuperScan version 4 has a number of useful features:

- Adjustable scanning speed
- Support for unlimited IP ranges
- Improved host detection using multiple ICMP methods
- TCP SYN scanning
- UDP scanning (two methods)
- Simple HTML report generation
- Source port scanning
- Fast hostname resolution
- Extensive banner grabbing capabilities
- Massive built-in port list description database
- IP and port scan order randomization
- A selection of useful tools, such as ping, traceroute, and whois
- Extensive Windows host enumeration capability

SIEM

Security Information Event Management (SIEM) is a technology used in enterprise organizations to provide real time reporting and long-term analysis of security events.

SIEM combines the essential functions of SIM and SEM to provide:

- **Forensic analysis** - The ability to search logs and event records from sources throughout the organization provides more complete information for forensic analysis.
- **Correlation** - Examines logs and events from disparate systems or applications, speeding detection of and reaction to security threats.
- **Aggregation** - Aggregation reduces the volume of event data by consolidating duplicate event records.
- **Retention** - Reporting presents the correlated and aggregated event data in real-time monitoring and long-term summaries.

SIEM provides details on the source of suspicious activity, including:

- User information (name, authentication status, location, authorization group, quarantine status)
- Device information (manufacturer, model, OS version, MAC address, network connection method, location)
- Posture information (device compliance with corporate security policy, antivirus version, OS patches, compliance with mobile device management policy)

22.3 Network Security Testing Summary

What Did I Learn in this Module?

- Operations security starts with the planning and implementation process of a network.
- The staff that sets up and conducts the security testing should have significant security and networking knowledge in these areas: device hardening, firewalls, IPSs, operating systems, basic programming, networking protocols, such as TCP/IP, and network vulnerabilities and risk mitigation.
- Many security tests can be conducted to assess the operational status of the network and include: penetration testing, network scanning, vulnerability scanning, password cracking, log review, integrity checkers, and virus detection.
- There are many tools available to test the security of systems and networks including: Nmap/Zenmap, SuperScan, SIEM, GFI LANguard, Tripwire, Nessus, L0phtCrack, and Metasploit.
- Nmap and Zenmap (its graphical frontend) are commonly used and free low-level scanners. SuperScan is also a free Microsoft Windows port scanning tool.
- Security Information Event Management (SIEM) is a technology used in enterprise organizations to provide real time reporting and long-term analysis of security events. SIEMs provide correlation, aggregation, forensic analysis, and retention.

New Terms and Commands

- Security Test and Evaluation (ST&E)
- Penetration testing
- Network scanning
- Log review
- Integrity checkers
- Virus detection
- Nmap/Zenmap
- SuperScan
- SIEM (Security Information Event Management)
- GFI LANguard
- Tripwire
- Nessus
- L0phtCrack
- Metasploit
- Forensic analysis

